Cybersecurity by Design for Critical Infrastructures

Laurea Magistrale in Informatica

alma.pennacchi@uniroma2.it

Aprile 2026

TOR VERGATA
UNIVERSITÀ DEGLI STUDI DI ROMA

Roadmap

1 From Logs to Workflows

Lezione 4 — Obiettivo

Domanda guida

Come ricostruiamo il comportamento di una infrastruttura a partire dai log, e come usiamo questa ricostruzione per distinguere fault, misconfiguration e attack?

- costruire un **grafo osservato** a partire dai log
- correlare **ciò che entra** con **ciò che esce**
- analizzare **workflow**, **connettività**, **propagazione** ed **entropia**

Perché i log sono centrali

Idea

Un log non è solo una traccia tecnica: è una osservazione parziale del comportamento del sistema.

- chi ha fatto qualcosa
- su quale risorsa
- quando
- con quale esito

Messaggio

Se correlati correttamente, i log permettono di ricostruire il comportamento operativo.

Che cosa può contenere un log utile

Un log utile può contenere:

- timestamp
- sorgente e destinazione
- utente / processo / servizio
- tipo di evento
- esito: ok, fail, retry, timeout
- contesto: protocollo, host, applicazione, zona

Osservazione

Più il log è ricco, più il comportamento ricostruito sarà preciso.

Dal log al grafo

Idea

A partire dai log possiamo costruire un grafo osservato del sistema.

- **nodo** = host, utente, servizio, processo, database, dispositivo
- **arco** = accesso, comunicazione, query, dipendenza, attivazione
- **tempo** = ordine degli eventi
- **peso** = frequenza, volume, numero di attivazioni

Dal log al nodo

Un log può introdurre o confermare l'esistenza di un nodo:

- host osservato in rete
- utente autenticato
- servizio che si attiva
- processo che apre una connessione

Idea

Il nodo rappresenta una entità osservabile che partecipa al comportamento del sistema.

Dal log all'arco

Un log può anche generare un arco:

- connessione tra due host
- query verso un database
- accesso a un servizio
- passaggio di stato o attivazione conseguente

$$\text{log} \Rightarrow (\text{sorgente}, \text{destinazione}, \text{tipo}, \text{tempo})$$

Messaggio

Il grafo non è solo topologia fisica: può rappresentare interazioni e dipendenze operative.

Grafo statico vs grafo temporale

Grafo statico

Dice *chi può parlare con chi*.

Grafo temporale

Dice *chi ha parlato con chi, quando e in quale sequenza*.

Punto chiave

Per la detection spesso il grafo temporale è più informativo del grafo statico.

Pipeline: Logs → Graph

Logs → Parsing → Entities → Edges → Graph

- parsing dei campi rilevanti
- normalizzazione delle entità
- deduplicazione
- correlazione temporale

Correlazione: ciò che entra deve spiegare ciò che esce

Idea

In un workflow normale, un input deve produrre un output coerente e spiegabile.

- richiesta $\rightarrow$ risposta
- comando $\rightarrow$ effetto
- evento in ingresso $\rightarrow$ transizione di stato

Segnale forte

Se non riesco a spiegare l'output a partire dall'input, c'è un problema di coerenza.

Casi di incoerenza

Esempi di incoerenza:

- risposta senza richiesta tracciabile
- attivazione senza evento causale precedente
- modifica dello stato senza comando atteso
- output incompatibile con l'input osservato

Interpretazione

L'incoerenza può indicare fault, bug, bypass, attacco o perdita di osservabilità.

Dal grafo al workflow

Idea

Il grafo osservato può essere letto come un insieme di workflow: sequenze di attivazioni, accessi, query e transizioni.

- login $\rightarrow$ autorizzazione $\rightarrow$ accesso
- richiesta $\rightarrow$ DB $\rightarrow$ risposta
- evento dispositivo $\rightarrow$ applicazione $\rightarrow$ storage

Workflow normali vs workflow anomali

Un workflow è anomalo quando presenta:

- passi mancanti
- passi fuori ordine
- attivazioni inattese
- dipendenze non censite
- output non spiegabili

Punto chiave

L'attacco spesso si vede meglio come **workflow anomalo** che come evento isolato.

Perché la connettività è importante

La connettività determina:

- chi può raggiungere chi
- dove può propagarsi un errore
- dove può muoversi un attaccante
- quali nodi fanno da ponte

Messaggio

La sicurezza non dipende solo dai nodi, ma dalla struttura delle connessioni tra i nodi.

Reachability e propagazione

Idea

Se un nodo compromesso o malfunzionante può raggiungere molti altri nodi, il rischio sistemico cresce.

- cammini disponibili
- zone attraversabili
- dipendenze attivabili
- servizi raggiungibili

Nodi ponte e punti critici

Nel grafo alcuni nodi sono più sensibili di altri:

- nodi che collegano due sottoreti
- servizi centrali
- gateway
- database condivisi

Interpretazione

Se un nodo ponte si altera, può propagare rapidamente fault o attacchi.

Propagazione: fault o attack?

Osservazione

Se un'anomalia resta locale, può essere minore. Se si propaga, la severità cambia.

La propagazione può indicare:

- malfunzionamento sistemico
- misconfigurazione che si diffonde
- attacco che sfrutta la connettività

Messaggio

La propagazione è un segnale forte: il problema non è più locale, ma strutturale.

Entropia e comportamento del sistema

Idea

L'entropia misura quanto il comportamento osservato diventa disperso, vario o imprevedibile.

Può essere applicata a:

- destinazioni
- path
- attivazioni
- distribuzione dei flussi

Entropia della connettività

Se improvvisamente:

- aumentano le destinazioni diverse
- aumentano i path attivi
- aumentano i pattern di attivazione

allora l'entropia cresce.

Interpretazione

Un aumento improvviso di entropia può segnalare propagazione, scanning, malfunzionamento o riconfigurazione inattesa.

Knowledge Base vs sistema osservato

Idea

Il sistema osservato deve essere coerente con ciò che il modello, il database o l'inventario dichiarano.

Esempi:

- componente attivo non censito
- path osservato ma non previsto
- servizio che si attiva senza essere dichiarato
- relazione che non esiste nella base dati

Incoerenza come segnale forte

Segnale critico

Se osservo una attivazione, una relazione o un workflow che non esiste nella knowledge base, il sistema sta facendo qualcosa che non so spiegare.

- inventario incompleto
- misconfigurazione
- shadow component
- attacco

Fault, Misconfiguration o Attack?

Per distinguere queste tre classi non basta il singolo log.
Servono insieme:

- correlazione input/output
- coerenza del workflow
- struttura del grafo
- propagazione
- entropia
- coerenza con la knowledge base

Pipeline finale

$$\text{Logs} \rightarrow \text{Graph} \rightarrow \text{Workflow} \rightarrow \text{Propagation} \rightarrow \text{Decision}$$

Idea

L'obiettivo non è solo leggere eventi, ma ricostruire il comportamento del sistema e valutarne la coerenza.

Conclusioni

Idea centrale

I log diventano davvero utili quando permettono di ricostruire **grafo**, **workflow** e **propagazione**.

Conclusione

Un attacco o un fault sistemico non si riconosce solo dal singolo evento, ma da come il comportamento si struttura, si correla e si diffonde.